

Презентация по лабораторной работе №3

Еюбоглу Тимур, Зиязетдинов Алмаз, Исаев Булат

24 ноября 2025 г.

Российский университет дружбы народов, Москва, Россия

- Еюбоглу Тимур
- 1032224357
- уч. группа: НПИбд-01-22
- Факультет физико-математических и естественных наук
- Российский университет дружбы народов

Изучить сценарий атаки внешнего злоумышленника на контроллер домена предприятия с целью получения доступа к внутренним ресурсам компании. Освоить методы обнаружения, анализа и устранения последствий компьютерных атак с использованием программного комплекса “Ampire”, включая выявление уязвимостей, таких как SQL-инъекция, отключенная защита антивируса и слабые пароли, а также их последствия.

Внешний злоумышленник находит сайт компании в интернете и проводит атаку на него для получения доступа к внутренним ресурсам. Обнаружив уязвимости на внешнем периметре, закрепляется на сервере и проводит разведку сети для захвата контроллера домена. Нарушитель обладает средней квалификацией, умеет использовать инструменты для атак и техники постэксплуатации, а также имеет опыт фишинговых рассылок.

Выполнение лабораторной работы

```
root@webportall:/var/www/html/htdocs/polygon# grep -r '$_GET'  
controllers/NewsController.php:         $id = $_GET['id'];  
root@webportall:/var/www/html/htdocs/polygon#
```

Рис. 1: Поиск места уязвимого параметра

Параметры уязвимой функции

```

Select C:\Windows\system32\cmd.exe
C:\U
user@webportal1: /var/www/html/htdocs/polygon
GNU nano 2.7.4 File: controllers/NewsController.php
Pr ?php
TC
^C
class NewsController extends Controller
C:\U
{
'cle
oper
    public function actionIndex()
    {
        $models = News::model()->findAll();
        foreach ($models as $key => $model) {
            $models[$key][4] = News::model()->commentsCount($model[0]);
        }
        $this->render('news/index', array('model'=>$models));
    }
    public function actionView()
    {
        $id = $_GET['id'];
        $model = News::model()->findById($id);
        $comments = Comment::model()->findByAttributes(array('post_id'=>$id));
        $this->render('news/view', array('model'=>$model, 'comments'=>$comments));
    }
    public function actionAddComment()
    {
        $model = Comment::model()->create(array(
            'name'=>$_POST['name'],
            'email'=>$_POST['email'],
            'text'=>$_POST['text'],
            'post_id'=>$_POST['post_id'],
        ));
        header('Location: ' . $_SERVER['HTTP_REFERER']);
        exit();
    }
}
^G Get Help ^O Write Out ^W Where Is ^K Cut Text ^J Justify ^C Cur Pos
^X Exit ^R Read File ^\ Replace ^U Uncut Text ^T To Spell ^_ Go To Line
```

```
public function actionView()
{
    $id = $_GET['id'];
    if (!is_numeric($id)){
        $id = 1;
    }
    $model = News::model()->findbyid($id);
    $comments = Comment::model()->findByAttributes(array('post_id'=>$id));
    $this->render('news/view', array('model'=>$model, 'comments'=>$comments));
}

public function actionAddComment()
{
    // ...
}
```

Рис. 3: Параметры уязвимой функции

4.2 Последствие Web portal meterpreter

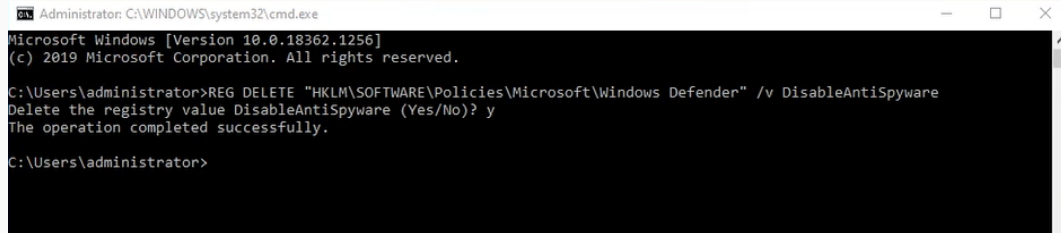
```
root@webportall:/var/www/html/htdocs/polygon# ss -tp
State      Recv-Q Send-Q Local Address:Port      Peer Address:Port
ESTAB      0      0      10.10.1.20:45326        195.239.174.11:4444
            users: (("chisel.sh",pid=10995,fd=3), ("sh",pid=10994,fd=3), ("gFTZFb",pid=989
2,fd=3))
ESTAB      0      272     10.10.1.20:ssh         10.10.1.253:23052
            users: (("sshd",pid=24046,fd=4), ("sshd",pid=24037,fd=4))
ESTAB      0      0      10.10.1.20:40790        195.239.174.11:1085
            users: (("chisel.sh",pid=10995,fd=11))
ESTAB      0      0      10.10.1.20:53238        10.10.1.25:5044
            users: (("filebeat",pid=698,fd=5))
ESTAB      0      0      10.10.1.20:tpoxy        10.10.1.253:4037
            users: (("server",pid=620,fd=8))
ESTAB      0      0      10.10.1.20:33178        10.10.2.17:25004
            users: (("epp_agentd",pid=30816,fd=36))
root@webportall:/var/www/html/htdocs/polygon# ss -K dst
```

Рис. 4: Список установленных соединений

```
root@webportall:/var/www/html/htdocs/polygon# ss -K dst '195.239.174.11' dport = 4444
Netid  State      Recv-Q Send-Q      Local Address:Port      Peer Address:Port
tcp    ESTAB      0      0      10.10.1.20:45326        195.239.174.11:4444
root@webportall:/var/www/html/htdocs/polygon#
```

Рис. 5: Завершение сессии с нарушителем

4.3 Отключенная защита антивируса



```
Administrator: C:\WINDOWS\system32\cmd.exe
Microsoft Windows [Version 10.0.18362.1256]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\Users\administrator>REG DELETE "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v DisableAntiSpyware
Delete the registry value DisableAntiSpyware (Yes/No)? y
The operation completed successfully.

C:\Users\administrator>
```

Рис. 6: Удаление записи DisableAntiSpyware в реестре

Security at a glance

See what's happening with the security and health of your device and take any actions needed.



Virus & threat protection

Tamper protection is off. Your device may be vulnerable.

Turn on

[Dismiss](#)



Account protection

No action needed.



Firewall & network protection

Firewalls are turned off. Your device may be vulnerable.

Turn on



Family options

Manage how your family uses their devices.

Virus & threat protection

Protection for your device against threats.

Current threats

No current threats.

Last scan: Not available

Quick scan

[Scan options](#)

[Allowed threats](#)

[Protection history](#)

Virus & threat protection settings

No action needed.

[Manage settings](#)



Virus & threat protection updates

Security intelligence is up to date.

Last update: Not available

[Check for updates](#)

4.4 Последствие Admin meterpreter

Administrator: Windows PowerShell

PS C:\Users\administrator> netstat -ano | more

Active Connections

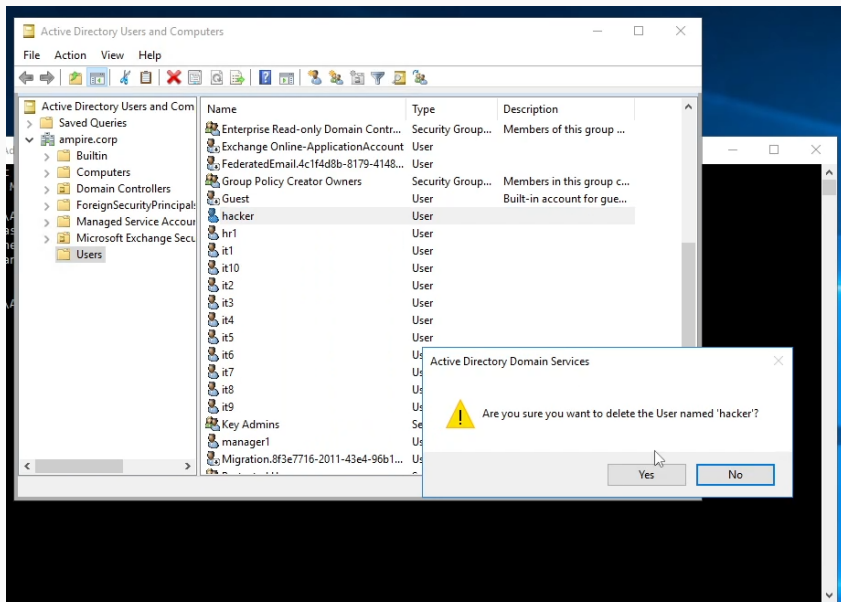
Proto	Local Address	Foreign Address	State	PID
TCP	0.0.0.0:135	0.0.0.0:0	LISTENING	980
TCP	0.0.0.0:445	0.0.0.0:0	LISTENING	4
TCP	0.0.0.0:3389	0.0.0.0:0	LISTENING	1072
TCP	0.0.0.0:5040	0.0.0.0:0	LISTENING	6648
TCP	0.0.0.0:49664	0.0.0.0:0	LISTENING	720
TCP	0.0.0.0:49665	0.0.0.0:0	LISTENING	544
TCP	0.0.0.0:49666	0.0.0.0:0	LISTENING	1552
TCP	0.0.0.0:49667	0.0.0.0:0	LISTENING	1356
TCP	0.0.0.0:49669	0.0.0.0:0	LISTENING	2636
TCP	0.0.0.0:49671	0.0.0.0:0	LISTENING	3248
TCP	0.0.0.0:49672	0.0.0.0:0	LISTENING	720
TCP	0.0.0.0:49709	0.0.0.0:0	LISTENING	3164
TCP	0.0.0.0:49721	0.0.0.0:0	LISTENING	712
TCP	10.10.4.10:139	0.0.0.0:0	LISTENING	4
TCP	10.10.4.10:3389	10.10.4.12:58951	ESTABLISHED	1072
TCP	10.10.4.10:49670	10.10.2.10:445	ESTABLISHED	4
TCP	10.10.4.10:49673	10.10.2.10:135	TIME_WAIT	0
TCP	10.10.4.10:49674	10.10.2.10:135	TIME_WAIT	0
TCP	10.10.4.10:49675	10.10.2.10:135	TIME_WAIT	0
TCP	10.10.4.10:49676	10.10.2.10:135	TIME_WAIT	0
TCP	10.10.4.10:49677	10.10.2.10:49671	TIME_WAIT	0
TCP	10.10.4.10:49678	10.10.2.10:49671	TIME_WAIT	0
TCP	10.10.4.10:49679	10.10.2.10:49671	TIME_WAIT	0
TCP	10.10.4.10:49680	10.10.2.10:49671	TIME_WAIT	0
TCP	10.10.4.10:49696	10.10.2.10:135	TIME_WAIT	0
TCP	10.10.4.10:49697	10.10.2.10:49671	TIME_WAIT	0
TCP	10.10.4.10:49738	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49739	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49740	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49741	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49742	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49745	10.10.4.13:139	TIME_WAIT	0
TCP	10.10.4.10:49753	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49754	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49755	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49758	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49759	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49765	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49766	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49767	10.10.2.15:80	TIME_WAIT	0
TCP	10.10.4.10:49768	195.239.174.12:443	TIME_WAIT	0
TCP	10.10.4.10:49769	10.10.2.15:80	TIME_WAIT	0
TCP	10.10.4.10:49770	10.10.2.15:80	TIME_WAIT	0
TCP	10.10.4.10:49771	195.239.174.12:443	TIME_WAIT	0

4.5 Слабый пароль учетной записи

```
PS C:\Users\administrator> net user Administrator *  
Type a password for the user:  
Retype the password to confirm:  
The passwords do not match.  
  
Type a password for the user:  
Retype the password to confirm:  
The command completed successfully.  
  
PS C:\Users\administrator> █
```

Рис. 10: Изменение пароля администратора

4.6 Последствие AD User



Вывод

В ходе лабораторной работы был изучен сценарий атаки на контроллер домена предприятия с использованием уязвимостей SQL-инъекции, отключенной антивирусной защиты и слабых паролей. Освоены методы детектирования атак с помощью ViPNet IDS NS, ViPNet TIAS и Security Onion, а также способы устранения последствий. Полученные навыки позволяют эффективно защищать корпоративные сети от внешних угроз средней сложности.

Отработали навыки проведения комплексной кибератаки в контролируемой среде, имитирующей реальную корпоративную сеть.